

API SECURITY RISK ANALYSIS

TASK 3

Prepared by Boikarabelo Alithia Mogwerane

May 2026

TABLE OF CONTENTS

INTRODUCTION	2
TOOLS USED	3
OBJECTIVE	3
API TESTED	3
METHODOLOGY	4
Evidence & Screenshots.....	4
SECURITY FINDINGS.....	6
RECOMMEDATIONS:	9
CONCLUSION	10

INTRODUCTION

This report represents a security risk analysis of a public demo API using safe and read-only testing methods.

The purpose of the task was to identify common API security risks, evaluate authentication and response handling, and provide remediation recommendations based on industry best practices.

The analysis was conducted ethically and did not involve exploitation, denial-of-service attacks, or unauthorized access attempts.

TOOLS USED

- Postman: API testing and request inspection
- Browser Development Tools: Header and response
- Microsoft Word: Documentation and reporting

OBJECTIVE

- Analyze a public API
- Identify common API security risks
- Review authentication and response handling
- Assess API security controls
- Recommended remediation measures

API TESTED

API NAME:

JSONPlaceholder Test API

BASE URL:

<https://jsonplaceholder.typicode.com>

Endpoint Tested:

<https://jsonplaceholder.typicode.com/users>

METHODOLOGY

- Performed read-only GET request
- Inspected API response headers
- Reviewed response body data
- Checked authentication requests
- Analyzed rate limiting behavior
- Evaluated information disclosure risks

No destructive testing was performed.

Evidence & Screenshots

Figure 1: API REQUEST AND REPONSE STATUS:

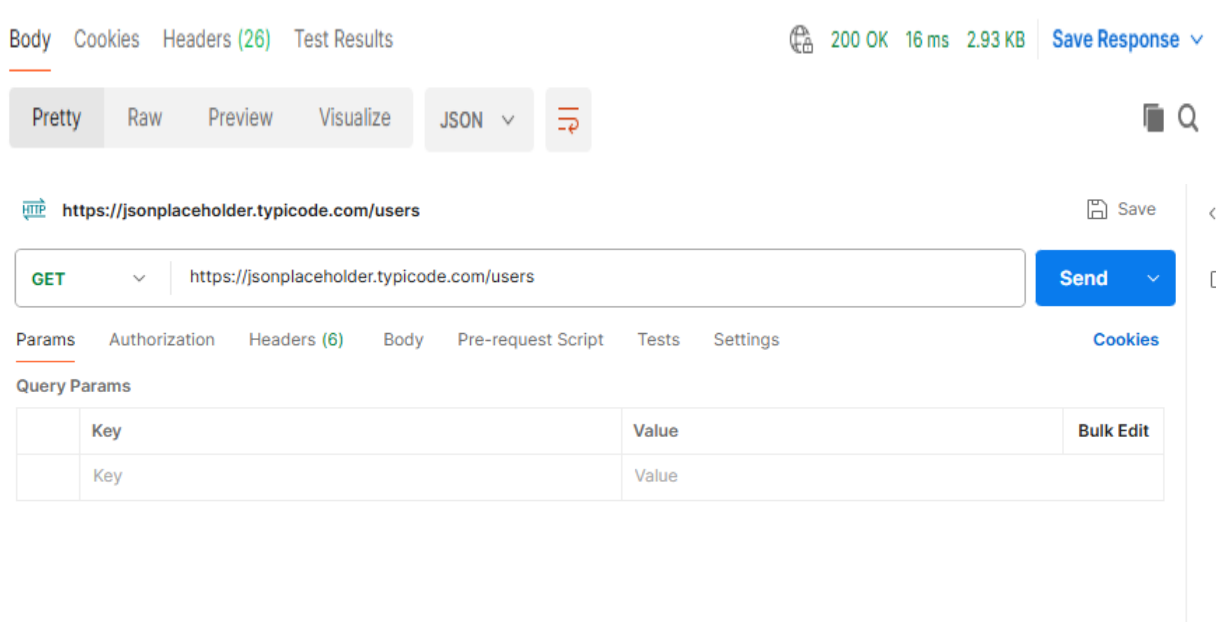


FIGURE 2: API REPONSE BODY

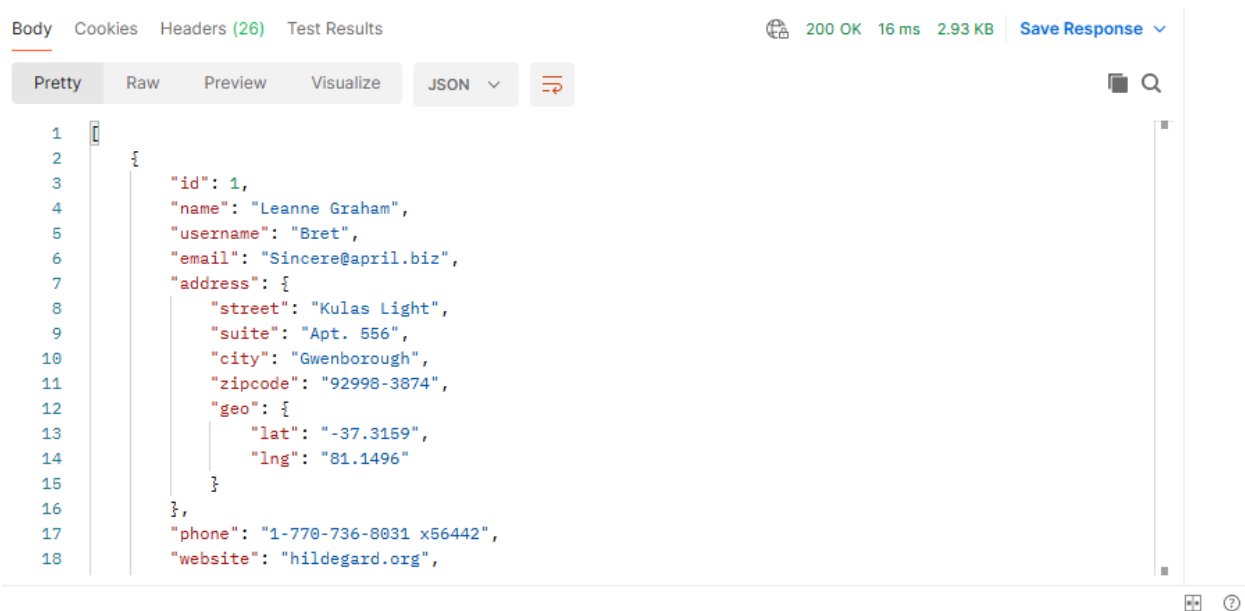


FIGURE 3: API REPONSE HEADERS

Body	Cookies	Headers (26)	Test Results	200 OK 16 ms 2.93 KB	Save Response
		x-content-type-options ⓘ	nosniff		
		x-powered-by ⓘ	Express		
		x-ratelimit-limit ⓘ	1000		
		x-ratelimit-remaining ⓘ	997		
		x-ratelimit-reset ⓘ	1777075245		
		age ⓘ	17120		
		accept-ranges ⓘ	bytes		
		cf-cache-status ⓘ	HIT		
		cf-ray ⓘ	a0106f07f95e5de5-JNB		
		alt-svc ⓘ	h3=":443"; ma=86400		

SECURITY FINDINGS

FINDING 1: No Authentication Required

- Severity:

Medium

- Description:

The API endpoint was accessible without requiring authentication, API keys, or login credentials. Requests to the /users endpoint returned user information publicly.

- Business Impact

Unauthenticated access increases the risk of unauthorized data access and information harvesting by attackers

- Recommendation

Implement authentication controls such as API keys, OAuth, or JWT authentication for sensitive endpoints.

FINDING 2: Excessive Data Exposure

- Severity:

Medium

- Description

The API response exposed multiple user-related fields including:

- Email addresses
- Phone numbers
- Physical addresses
- Physical addresses
- Company information

- Business Impact:

Exposed information may be used in publishing, spam, or social engineering attacks,

- Recommendation

Limited API responses only the data required by the application.

FINDING 3: Server Technology Disclosure

- Severity:

Low

- Description

The response header disclosed backend technology information through the following header:

X-powered-by: Express

- Business Impact:

Technology disclosure may help attackers identify framework-specific vulnerabilities.

- Recommendation:

Remove unnecessary server identification headers from API responses.

FINDINGS 4: Missing Security Headers

- Severity

Low

- Description:

Several common HTTP security headers were not observed during testing including:

- Content Security Policy
- X frame
- Strict Transport Security

- Business Impact

Missing security headers may reduce protection against browser-based attacks.

- Recommendation:

Configure recommended security headers on the server,

FINDINGS 5: Rate Limiting Detected

- Severity:

Positive Security Control

- Description:

The API implemented rate limiting mechanisms as indicated by the following headers

x-ratelimit-limit

x-ratelimit-remaining

- Business Impact:

Rate limiting helps reduce automated abuse and excessive API requests

- Recommendation:

Continue maintaining and monitoring rate limiting policies.

RECOMMENDATIONS:

- Implement authentication mechanisms such as API keys or JWT authentication
- Limit API responses to only necessary data fields
- Remove unnecessary server disclosure headers
- Configure secure HTTP security headers
- Continue enforcing rate limiting controls
- Regularly review API security configurations and access controls

CONCLUSION

The task identified several common API security risks, including missing authentication, excessive data exposure, server technology disclosure, and missing security headers.

Although the JSONPlaceholder API is intentionally designed for testing purposes, the findings demonstrated the importance of securing APIs in production environments. Proper authentication, security header implementation is essential for protecting sensitive data and reducing attack surfaces.